E-Carnet — Reste à faire et points partiels (liste consolidée)

Établie le 24 octobre 2026 à partir de l'archive de code v2_9, des fichiers .md du dépôt (feuilles de route, recette, sécurité, audit, QA, juridique, notes de modification) et du cahier des charges v11. Rien n'a été rejoué : ce sont les mentions « à faire », « partiel » et « non vérifié » trouvées dans ces sources.

Légende des sources : CDC (cahier des charges v11) · ETAT (état réel V1) · SEC (sécurité) · ARCHI (architecture) · DEPLOY (déploiement) · REC (recette V1, critères CA-01 à CA-24) · QA (rapport du 23/10) · LEGAL (conformité et champs à compléter) · QUEST (décisions A1 à A16) · V2 (feuille de route et suivi V2) · PLAN (plan V1) · MOD (notes du 22 au 24/10).

1. Les dix blocages avant toute vraie donnée

1. Lancer tous les tests Python, dont les nouveaux, jamais exécutés (QA, CDC).
2. Faire les 4 vérifications en préproduction : deux comptes médecins isolés, impossibilité de « réapprouver » un médecin parti, scan d'un QR de bout en bout sur Android et iPhone (QA).
3. Mettre en place un environnement de test séparé (staging) avec sauvegardes planifiées, restauration testée et délais de reprise mesurés (README, REC CA-22).
4. Remplacer Cloudinary par un stockage privé chez l'hébergeur : hors mode développement, l'envoi de documents échoue sans lui (CDC, LEGAL).
5. Obtenir les confirmations écrites de Hodi et choisir l'offre (CDC section 6).
6. Obtenir l'avis juridique et l'autorisation de l'ARTCI, y compris pour la sauvegarde en Allemagne (LEGAL, CDC).
7. Rejouer les tests sur PostgreSQL de l'instance cible : QR à usage unique, journal protégé, droits de suppression (SEC, README).
8. Tester sur de vrais téléphones et en 4G, et vérifier l'accessibilité (REC CA-23, QA).
9. Renouveler les secrets de l'archive (`.env`, base de test) et ne plus la diffuser (LEGAL, CDC).
10. Faire signer les critères d'acceptation CA-01 à CA-24 et décider formellement d'ouvrir ou de reporter (README, REC).

2. PARTIEL : présent dans le code mais incomplet

Fonction	Ce qui manque	Source
Connexion Google, Facebook, Apple	Identifiants réels, essais avec chaque fournisseur, test de la connexion Apple, remplacement d'un composant de connexion en fin de vie	ETAT, REC CA-01, CDC
Récupération de compte	Aujourd'hui la réponse à la question secrète suffit à choisir un nouveau mot de passe. La vérification par e-mail ou SMS et la protection contre la découverte d'adresses sont à terminer	ARCHI, V2, CDC
Mentions légales, confidentialité, conditions	Textes provisoires ; hébergeurs issus de l'ancienne configuration ; adresses et régions manquantes	LEGAL, CDC
Plans de suivi	Le médecin les crée par l'API ; interface professionnelle dédiée à ajouter ; graphiques riches à finaliser	V2, CDC
Rendez-vous	Première version seulement ; dépend de données fiables sur les établissements	CDC

Fonction	Ce qui manque	Source
Modèles de pré-consultation de l'établissement	Disponibles côté technique seulement	CDC, V2
Recherche rapide et listes denses du médecin	Prévues à la feuille de route, non vérifiées dans le code	CDC
Lecture du QR par la caméra	Bug de démarrage corrigé ; permissions sur iOS Safari et Chrome Android, mode photo de secours non essayés sur appareil réel	MOD, QA
Clôture et correction d'une consultation	Il manque un addendum de correction après clôture, à valider médicalement (édition refusée après clôture)	REC CA-08
Demande d'établissement par e-mail	Adresse officielle, réception et examen hors application, durée de conservation des preuves à formaliser	REC CA-02, FLOW
Journal d'audit protégé	Protection contre la suppression globale (`TRUNCATE`) à compléter et à vérifier sur la base cible	SEC, README, REC CA-18
Sauvegarde et restauration	Test local réussi ; sauvegardes planifiées, copie externe, délai de perte de données non mesuré (la seconde de test ne mesure que la commande)	REC CA-22, README
Tests de bout en bout	Un seul parcours automatisé ; parcours connectés et de consentement à écrire	V2
Apparence (palettes, polices, tailles)	Synchronisation entre appareils et cache à confirmer par tests	ETAT
Carte d'urgence	Formats d'export (QR en SVG, PDF personnalisable, PNG) à confirmer	CDC
Export PDF du carnet	Contenu exporté, avertissement et journal des exports à contrôler ; portabilité complète à cadrer	V2, CDC
Attestation SVG	Rendu et stockage à rejouer en staging ; usage clinique exact à valider	REC CA-17, SEC
Rubriques en tuiles et effet « goutte »	Contrôlés par captures sur ordinateur, pas sur téléphone réel	MOD
Navigation et icônes	Des symboles Unicode servent encore d'icônes ; la composition mobile reste à rapprocher des maquettes	ARCHI, QUEST
Console d'administration	Durcissement avant production ; accès superadministrateur sans double vérification (reporté V3) ; règles d'accès du personnel non écrites	SEC, LEGAL
Envoi d'e-mails	Configuration réelle, SPF, DKIM, DMARC, délivrabilité à vérifier	DEPLOY, PLAN
Profils d'enfants	Seuil d'âge légal non configuré par défaut (il bloque création et transfert) ; délégations d'adultes non ouvertes	SEC, ARCHI
Fiche d'établissement visible des médecins	Un médecin qui a eu un rattachement, même refusé ou terminé, voit la fiche complète : restreindre ou assumer (décision produit)	QA
Clé de chiffrement des codes médecin	Elle dérive de la clé de l'application ; si elle change, les codes affichés deviennent illisibles. À documenter dans le guide d'exploitation	QA
Dépendances verrouillées	Régénérer le fichier verrouillé (`make lock`) après l'ajout de « cryptography »	QA
Audit qualité du 23/10	Trois failles corrigées ; verdict provisoire « bloqué » tant que les tests et vérifications ne sont pas faits	QA, CDC

3. À FAIRE : absent du produit ou jamais réalisé

3.1 Exploitation et hébergement

- Environnement de test séparé avec données fictives (README, CDC).
- Sauvegardes planifiées, copie conservée en Côte d'Ivoire, restauration testée, objectifs de perte de données et de délai de reprise approuvés (REC CA-22).
- Stockage privé local pour documents, logos, cachets, signatures et avatars, et suppression de compte adaptée (CDC).
- Faire tourner l'interface et le service chez l'hébergeur retenu, sur un même domaine, avec des cookies plus stricts (CDC).
- Domaine, HTTPS, cookies et protection CSRF réels ; essais Android et iOS (README).
- Cache de limitation de débit partagé entre plusieurs serveurs en production (DEPLOY).
- Planifier le nettoyage quotidien des QR expirés et, si la durée de 90 jours est maintenue, celui des visites : aucune tâche ne les lance aujourd'hui (REC CA-09, LEGAL).
- Surveillance sans données de santé, alertes, journaux de production (V2, QA).
- Rejouer la mise à jour de base `establishments/0010` sur une copie de préproduction (QA).
- Mesurer le volume réel de documents par patient et plafonner les PDF, qui ne sont pas compressés (CDC).
- Commander un mois de Site Pro sans engagement et dérouler la liste de tests avec des données fictives (CDC 6.7).

3.2 Sécurité et tests

- Tests d'isolation avec deux vrais comptes, erreur 500 provoquée sans trace visible, recherche de secrets dans le code livré au navigateur (QA).
- Rejouer la concurrence du QR et les droits de la base sur PostgreSQL de la cible (README, REC CA-09, CA-13).
- Audit des dépendances à refaire avant chaque livraison ; test de la connexion Apple (ETAT).
- Revue de sécurité indépendante (provision de 1,0 M FCFA dans le business plan).
- Tests de non-régression pour qu'aucun compte ou écran infirmier autonome n'apparaisse (REC CA-24).
- Décider le délai d'attente après révocation ou expiration d'un QR (REC CA-09).

3.3 Mobile, accessibilité et utilisateurs

- Tests sur Android, iOS et 4G : QR de consultation, carte d'urgence, installation de l'application (ETAT, REC CA-23).
- Audit d'accessibilité complet (WCAG 2.2 AA) : clavier, lecteur d'écran, contraste, zoom à 200 % (ETAT, QA).
- Cinq tests avec de vrais utilisateurs : personne âgée, jeune, professionnel pressé (CDC).
- Mesures de performance (Core Web Vitals) et matrice navigateurs par appareils (QA).

3.4 Fonctions du produit (version 2)

- **Lot A :** réinitialisation du mot de passe vérifiée ; alertes d'échec d'envoi d'e-mail ; remplacement d'un administrateur d'établissement et suspension d'un établissement dans l'interface ; journal d'audit consultable par l'équipe ; tests automatisés connectés ; surveillance (V2, CDC).
- **Lot B :** tableau de bord de l'établissement (compteurs de médecins, codes, demandes) ; résumé périodique des accès ; audit d'accessibilité instrumenté (V2).

- **Lot C, après validation du lot A :** plusieurs administrateurs avec droits précis ; export contrôlé du carnet ; lecture hors connexion protégée ; modèles de pré-consultation configurables ; rendez-vous et rappels fiables côté établissement ; contenus éducatifs en français relus médicalement ; suivi de grossesse, d'enfant et de croissance ; statistiques anonymisées et limitées au nécessaire ; mode faible débit ; langage simple, pictogrammes et lecture audio (V2).
- **Divers :** liste des patients récents, avec règles de confidentialité (CDC) ; mesures de tension et de glycémie avec graphiques une fois les données validées (V2).
- **Pour le modèle économique :** suivi des abonnements et des factures ; groupes de comptes rattachés à une organisation qui paie ; statistiques anonymisées pour les programmes de santé publique (CDC, business plan).
- **Parcours d'inscription des professionnels (demande du 24/10) :** après les étapes 1 (identité) et 2 (contexte), tout le monde remplit l'étape 3 de l'onboarding patient ; le professionnel y ajoute un bloc « Profil professionnel » (spécialité, cachet et signature facultatifs), puis passe à l'étape 4 (sécurité). Il arrive dans son espace patient prêt et bascule par « Changer d'espace ». À coder : redirection de l'étape 2, bloc professionnel dans l'étape 3, création des deux espaces, tests. Décision à confirmer : bloc obligatoire à l'étape 3 ou reportable au premier changement d'espace (CDC 3.6).

4. Juridique et conformité

Porte de recette n° 3 : non ouverte (LEGAL) : 41 champs à compléter, aucun avis juridique rendu, cookie de mesure non tranché, recette navigateur et staging non faite.

Point	Ce qu'il reste à faire	Source
Cookie de mesure des visites	Déposé dès la première visite, sans choix préalable ; identifiant stable de 30 jours (« pseudonymisé », pas « anonyme »). À trancher avec le juriste	LEGAL
Durée de conservation des visites (90 jours)	N'est appliquée que si quelqu'un lance la commande ; la planifier ou la retirer	LEGAL
Vocabulaire « anonyme »	Remplacer par « pseudonymisé » dans les textes et la documentation (le nom `AnonymousVisitor` aussi)	LEGAL
Données de couverture et adresse du patient	Décision de minimisation : les garder ou non	LEGAL
Identifiant professionnel du médecin	Champ jamais rempli : le supprimer ou le documenter ; durée de conservation à décider	LEGAL, audit
Identité de l'aidant en texte libre	Aucun cadre juridique défini (décision A7)	LEGAL
Adresse IP dans les compteurs de limitation	À mentionner dans la politique (conservée au plus 1 h)	LEGAL
Photo de profil stockée en base de test	Question à poser au juriste	LEGAL
Accès du personnel à la console	Règles d'accès à écrire, double vérification reportée en V3	LEGAL
Promesses de la page d'accueil	« en un scan », « à tout moment », « chaque lecture », « V1 stable », « socle sécurisé » : à reformuler	LEGAL
Appellation de l'autorité de protection	Confirmer le nom actuel (ARTCI)	LEGAL
Conservation, correction, export, suppression (décision A15)	Durées et règles à faire approuver par un juriste	QUEST
Incidents et notifications (décision A16)	Responsables, seuils, délais, confinement et notification à définir	QUEST
Conditions de rattachement du médecin	Texte versionné, projet fonctionnel à valider juridiquement avant tout usage contractuel	FLOW
Preuves reçues par e-mail pour les établissements	Règle de conservation et de sécurité de la boîte à formaliser	FLOW, ARCHI
Ordonnance PDF	Acceptation juridique et pharmaceutique non présentée comme acquise ; champs médicaux (décision A10) à valider	REC, V2

Point	Ce qu'il reste à faire	Source
Hébergement et sauvegarde	Autorisation de l'ARTCI pour les données médicales et pour la copie en Allemagne ; « instruction spécifique » exigée par Hodi ; contrat de sous-traitance	CDC 6.3, 7
Cloudinary	Localisation, sauvegardes, accès du support et transferts hors du pays à faire confirmer	LEGAL, TODO
Statut et facturation	Immatriculation au CEPICI, inscription à la FNE, prestataire de paiement agréé	CDC 7
Neuf questions fermées	À poser aux juristes (CDC section 7)	CDC

5. REPORTÉ : V3, V4 à V6

- **V3 :** code SMS et double vérification ; notifications et rappels par SMS ; paiement Mobile Money ; messagerie patient–médecin ; partage entre deux établissements ; téléconsultation ; ordonnance électronique en pharmacie ; résultats de laboratoire ; accès délégués pour adultes ; assistant de préparation de consultation ; capteurs et nombre de pas (CDC 5.2).
- **V4 et V5 :** échange de données au format FHIR, accompagnement avancé, bien-être (CDC 5.3).
- **V6 :** espaces pharmacie et laboratoire.

6. Écarts entre documents et code

1. **Documents :** l'architecture et la décision A9 les classent « hors V1 », mais le code permet déjà aux médecins de les lire en lecture seule avec un accord du patient.
2. **Hébergement :** la note d'exploitation et la feuille de route V2 disent « Vercel, Render, Neon pour V1 et V2 », alors que la règle est « pas de données réelles avant un hébergement ivoirien ». Le schéma d'architecture parle encore d'un « stockage privé à compléter ».
3. **Nombre de tests :** 94, 119 puis 175 tests de l'interface selon les documents ; un seul chiffre daté à retenir.
4. **Dates :** le fichier principal date du 14/10 alors que le code évolue jusqu'au 24/10.
5. **PDF v11 fournis :** leurs chapitres hébergement et finances parlent encore du VPS et de Site Pro écarté (ils n'ont pas été mis à jour).
6. **Site public :** le journal du 18/10 indique que la mention « version pilote / données fictives » a disparu.
7. **Rapport d'audit ancien :** il a été en partie remplacé par des constats plus récents ; ses limites sont détaillées dans la sécurité et la recette.
8. **Fichiers superflus ou sensibles dans l'archive :** `apps/api/.env`, `apps/web/.env.production.local` (selon le dossier juridique), base de test `db.sqlite3`, et un fichier `jj` à la racine qui contient des commandes git.
9. **Deux titres de niveau 1** sur la page de connexion, et la feuille de style de l'en-tête public à confirmer au build de production (LEGAL).

7. Ce que le code ne contient pas encore

- Aucun module d’abonnement, de facturation ou de quota.
- Aucune entité « organisation qui paie » pour regrouper des comptes.
- Aucune compression des PDF avant envoi (seules les photos sont réduites).
- Aucun envoi de notifications par SMS ou par notification sur le téléphone.
- Aucune conversion de la tension et de la glycémie en courbes (texte libre).
- Un seul test navigateur automatisé.